

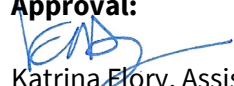


DAS Policy

No:
2100-03

System and Information Integrity

Effective:
November 20, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to define the requirements for system and information ***Integrity*** controls. These controls include business processes, coding, deployment, and ***Vulnerability*** management standards to ensure the Integrity of systems and the information they process or store.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, “Security and Privacy Controls for Federal Information Systems and Organizations,” family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy covers any ***DAS-Managed System Assets***, including system assets managed by external service partners.

III. Policy

The following system and information Integrity controls shall be applied to DAS-Managed System Assets, including those managed by external service partners:

- A. **Flaw Remediation (SI-2)**: DAS OIT shall identify and remediate ***System Flaws*** in accordance with Ohio Administrative Policy IT-20 Vulnerability Management and the associated standard, ITS-SEC-03.

B. **Malicious Code Protection (SI-3)**: DAS OISP shall provide **Malicious Code** protection at information system entry and exit points to detect and eradicate Malicious Code.

1. **Host** Protection: Host protection shall consist of tools to secure Hosts from **Malware** and network attacks. At a minimum, chosen solutions shall include, antivirus/antimalware, Host firewall, file Integrity checking, and Host IDS (intrusion detection system). All specified applications shall support central management.
2. DAS-managed Devices: All DAS-managed desktops, laptops, and servers shall run endpoint protection software provided by DAS OISP, and shall be kept current with operating system, software patches, and virus definitions.
3. Non-DAS-managed Infrastructure Devices: Infrastructure devices (e.g., servers, network gear, etc.) not owned by the state, but authorized for use in state business, shall meet all of the requirements outlined in this policy.
4. Currency: Malicious Code protection software shall be kept current with software and signature updates from the vendor.
 - a) Automatic updating, if available, shall be enabled.
 - b) System owners shall monitor devices to ensure they are receiving updates. Non-compliant systems present a security risk and shall be promptly remediated.
5. Scan Frequency: Automated scans for Malware shall be scheduled to run a full disk scan at least weekly on each device. Scans of network shares shall be coordinated with backup schedules.
6. Active (Real Time) Scanning: Active scanning of software downloaded or opened shall be enabled.
7. Testing: DAS OISP shall conduct testing, at least monthly, to ensure that the Malicious Code protection solution is functioning properly.
8. **Quarantine**: When Malicious Code is detected, the DAS OISP Security Incident Response Team (SIRT) and relevant system personnel shall be alerted. The detected file shall be Quarantined to allow for analysis when the Host is suspected of other malicious activity.

C. **Monitoring (SI-4)**: Devices shall be monitored to ensure that unusual activity is identified and investigated.

1. Systems that report malicious activity or attempts (e.g., personal firewall, Host Intrusion Prevention System (HIPS), antivirus, etc.) shall be configured to report this activity to the enterprise security information and event management (SIEM) solution via their central management system.
2. DAS OISP personnel shall monitor the SIEM for reports of Malware. In the event of a Malware infection, which appears to be spreading through the network, DAS OISP will offer assistance to affected users or system owners in halting the Malware's progress.

3. Personnel responsible for systems (e.g., system administrators and desktop support personnel) shall receive notifications, via e-mail or short message service (SMS), of Malware.
 4. System management and security personnel responsible for a server environment shall receive notifications, via e-mail or SMS, of any Malware detection within that server environment.
- D. **Security Alerts and Advisories (SI-5):** DAS OISP shall monitor alerts and advisories relating to system security through multiple third-party sources (e.g., Multi- State Information Sharing & Analysis Center). DAS OISP shall issue alerts to appropriate personnel (e.g., DAS security point of contact, system owners, service owners, etc.) with relevant security alerts received from third party sources.
- E. **Software, Firmware, and Information Integrity (SI-7):** DAS-managed systems shall employ file Integrity checking software, which shall be configured to ensure the Integrity of operating system files; firmware/Basic Input/Output System (BIOS)/Unified Extensible Firmware Interface (UEFI); and other system-specific files and programs identified as having Integrity requirements.
1. Integrity violations shall be reported to the enterprise SIEM. The security and system administration personnel responsible for the resource shall be alerted.
 2. Detected events shall be corrected by security and system administration personnel.
- F. **Email Protection (SI-8):** The state e-mail system shall employ email security best practices to detect and take action on unsolicited messages.
1. Email protection shall be kept current with vendor releases of any software or hardware components that are used to provide the email protection solution.
 2. Automatic updates of the email protection solutions and any learning capabilities of the system, which make the system more effective, shall be enabled.
- G. **Input Validation (SI-10):** Attackers may manipulate system inputs to compromise systems (e.g., SQL injection), therefore, systems shall utilize mechanisms to determine inputs are valid, authorized, and not malicious.
1. This control shall be applied to inputs regardless of source (e.g., end user input, file import, information scanned into the system, etc.).
 2. Invalid input from interactive user sessions shall provide appropriate error messages, which do not reveal information about the internal state of the system.

3. Invalid input received in file import shall be logged or displayed to a user at the time of import.

- H. **Error Handling (SI-11):** Error messages generated from DAS-managed information systems shall contain only the information necessary for corrective actions.

Information which could be exploited by adversaries shall not be revealed in error messages. Detailed error messages may be written to protected application logs but shall not be revealed to end users.

- I. **Information Handling and Retention (SI-12):** DAS Service Owners shall handle and retain both information within and output from the information system in accordance with applicable federal and state laws, executive orders, directives, policies, regulations, standards, and operational requirements.
- J. **Memory Protection (SI-16):** DAS-managed information system memory shall be protected from unauthorized code execution.

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- C. DAS-Managed System Asset. Information, hardware, software and services required to support state business, and identified during the risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- D. Host. A Host is any hardware device that has the capability of permitting access to a network via a user interface, specialized software, network address, protocol stack, or any other means. Some examples include, but are not limited to, computers, personal electronic devices, thin clients, and multi-functional devices.³

¹ "NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, September, 2020 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

² *Ibid.*

³ "Host" NIST Glossary. Web 18 July 2024 <<https://csrc.nist.gov/glossary/term/host>>.

- E. Integrity. Guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity.⁴
- F. Malicious Code. Software or firmware intended to perform an unauthorized process that will have an adverse impact on the **Confidentiality**, Integrity, or **Availability** of an information system. Some examples include a virus, worm, Trojan horse, or other code-based entity that infects a Host. Spyware and some forms of adware are also examples of Malicious Code.⁵
- G. Malware. A program that is inserted into a system, usually covertly, with the intent of compromising the Confidentiality, Integrity, or Availability of the victim's data, applications, or operating system or of otherwise annoying or disrupting the victim.⁶
- H. Quarantine. Store files containing Malware in isolation for future disinfection or examination.⁷
- I. System Flaw. Error of commission, omission, or oversight in an information system that may allow protection mechanisms to be bypassed.⁸
- J. Vulnerability. Weakness in an Information System, system security procedures, internal controls, or implementation that could be exploited by a threat source.⁹

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://csrc.nist.gov/publications/sp

⁴ "NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, September, 2020
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

⁵ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April 2013
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁶ Souppaya, Murugiah, Karen Scarfone. "NIST Special Publication 800-83, Revision 1, Guide to Malware Incident Prevention and Handling for Desktops and Laptops" U.S. Department of Commerce National Institute of Standards and Technology, July 2013, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-83r1.pdf>>.

⁷ Souppaya, Murugiah, Karen Scarfone. "NIST Special Publication 800-114 Rev. 1, User's Guide to Telework and Bring Your Own Device (BYOD) Security," U.S. Department of Commerce National Institute of Standards and Technology, July, 2016, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-114r1.pdf>>.

⁸ "CNSS Instruction No. 4009, National Information Assurance (IA) Glossary," Committee on National Security Systems, 6 April 2015 <https://www.ncsc.gov/publications/policy/docs/CNSSI_4009.pdf>.

⁹ "NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, September, 2020,
<<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

Document Name	Location
Ohio Administrative Policy IT-20 Vulnerability Management	https://das.ohio.gov/technology-and-strategy/policies/IT-20
State of Ohio IT Standard IT-SEC-03 Vulnerability Management	https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards/its-sec-03-vulnerability-management
Ohio IT Standard ITS-SEC-02 Enterprise Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies/its-sec-02-enterprise-security-controls-framework
Open Web Application Security Project (OWASP)	https://owasp.org/about/
Multi-State Information Sharing & Analysis Center (MS-ISAC)	https://www.cisecurity.org/ms-isac

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/01/2009	Original Policy
12/05/2012	Policy reissued under Director Robert Blair

Date	Description of Change
06/18/2018	Revised the policy to align with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, “Security and Privacy Controls for Federal Information Systems and Organizations,” System and Information Integrity family of controls.
11/26/2018	Updated the exception request language to align with the current procedure.
01/15/2020	Updated the policy template
05/21/2020	Added a reference to DAS-ITS-2100-03-A Security Vulnerability Remediation Standard.
05/28/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.
11/20/2024	Updated the policy to remove the vulnerability requirements and add a reference to Ohio Administrative Policy IT-20 Vulnerability Management, and the associated standard, ITS-SEC-03. Renamed the “Spam Protection” section to “Email Protection” to clarify the scope of the requirements.